面向网络设备的常见威胁及攻防工具能力比较分析



学　号 2453359

姓　名 李欣洋

专　业 信息安全

课程名称 网络空间安全导论

日　期 2025.11.26

摘要: 随着网络规模的不断扩大，路由器、交换机、防火墙、无线 AC、入侵防御系统（IPS）等关键网络设备成为保障网络运行与安全的核心环节。然而，这些设备在实际部署中仍面临路由协议劫持、MAC 表溢出、策略绕过、假 AP、流量规避及数据通道滥用等多种典型威胁。为此，本研讨报告选取 Nmap、Nessus、Metasploit 与 Wireshark 等常用攻防工具，从识别能力、漏洞覆盖、攻击验证与协议分析等维度进行比较分析，以评估其在不同设备安全防护中的适用性。

关键词: 网络设备；常见威胁；攻防工具；Nmap；Nessus；Metasploit

目录:

1. 引言

1.1 研究背景

- 网络设备作为网络核心的地位

1.2 研究意义与目的

- 理解不同网络设备面临的典型威胁

- 对常见攻防工具能力进行比较

2. 网络设备面临的威胁原理分析

2.1 路由器面临的常见威胁分析

- 路由器的基本功能和安全模型

- 路由协议劫持 —— OSPF 注入

- 默认管理口弱口令

2.2 交换机面临的常见威胁分析

- 交换机的基本功能和安全模型

- MAC 地址表溢出攻击

2.3 防火墙面临的常见威胁分析

- 防火墙的基本功能和安全模型

- 策略绕过

2.4 无线 AC 面临的常见威胁分析

- 无线 AC 的基本功能和安全模型

- 假 AP 攻击

2.5 入侵防御(IPS)面临的常见威胁分析

- 入侵防御(IPS)的基本功能和安全模型

- 加密流量隐藏攻击

- 误报/漏报带来的安全空洞

3. 网络攻防工具的分析

3.1 Nmap 工具分析

- 用途

- 在路由器、交换机、防火墙、无线 AC、入侵防御系统和网闸中的应用

- 能力优缺点

3.2 Nessus 工具分析

- 用途

- 在路由器、交换机、防火墙、无线 AC、入侵防御系统和网闸中的应用

- 能力优缺点

3.3 Metasploit 工具分析

- 用途

- 在路由器、交换机、防火墙、无线 AC、入侵防御系统和网闸中的应用

- 能力优缺点

4. 网络攻防工具的对比分析

1. 引言

1. 1 研究背景

随着信息化建设的快速发展，网络规模与复杂度显著提升，路由器、交换机、防火墙、无线 AC、入侵防御系统（IPS）以及网闸等关键设备已经成为现代网络的基础支撑。这些设备不仅承担着数据转发、访问控制、无线接入、流量检测及隔离防护等多项重要职责，同时也直接影响网络整体的可用性与安全性。然而，随着网络攻击技术的不断演进，针对这些设备的攻击手段也逐渐多样化，从早期的简单弱口令爆破发展到协议注入、数据伪造、流量规避等更具隐蔽性与破坏力的攻击方式。

1. 2 研究目的

为了有效保障网络设备在复杂环境中稳定运行，有必要深入理解不同类型网络设备面临的典型威胁，包括协议劫持、MAC 表溢出、策略绕过、假 AP、加密流量规避与数据通道滥用等攻击方式。同时，当前网络安全攻防过程中广泛使用了多种工具，如 Nmap、Nessus、Metasploit 和 Wireshark，不同工具在扫描、漏洞检测、利用验

证与协议分析方面具有不同能力。

2. 网络设备面临的威胁原理分析

2. 1 路由器面临的常见威胁分析

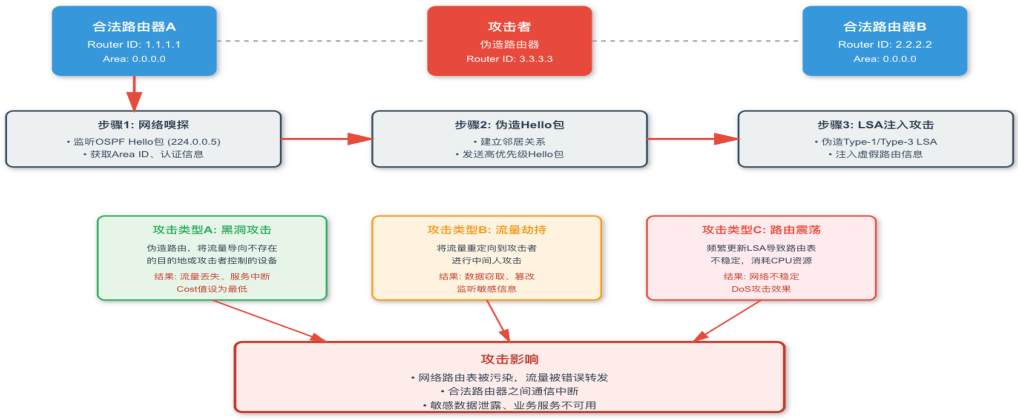
路由器负责不同 IP 子网之间的路径选择，维护路由表并执行报文转发。现代路由器还可能承担 NAT、ACL、策略路由、VPN 终端以及 BGP/OSPF 等路由协议。安全模型应覆盖：控制面（路由协议）、管理面（SSH/Telnet/HTTP/HTTPS）、数据面（转发路径与 ACL）三部分。

2. 1_1 路由协议劫持

OSPF 通过 LSA 广播链路状态。若攻击者能够伪造 LSA，邻居路由器会将伪造信息纳入拓扑计算，从而改变转发表。

其攻击流程可分为：

1. 获得与目标路由器相连的一台主机或旁路监听点
2. 使用未认证或被破解的路由协议发送恶意 LSA
3. 触发目标路由器重新计算最短路由，导致流量走向攻击者或黑洞

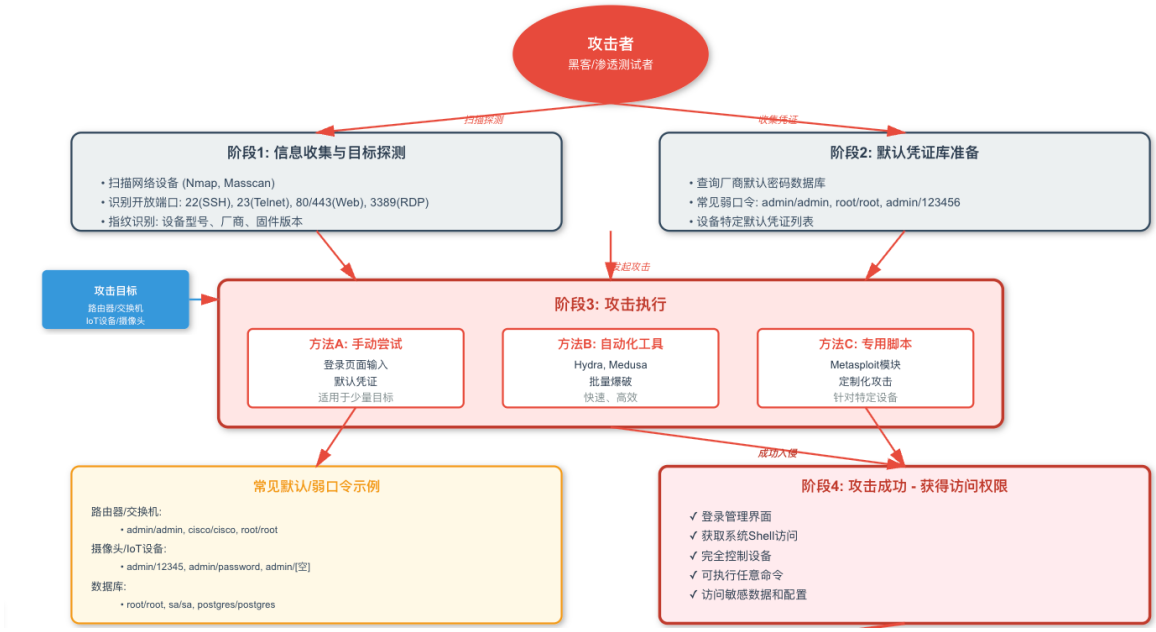


2. 1_2 默认管理弱口令

路由器管理口（Telnet/SSH/HTTP/HTTPS/SNMP）若使用默认/弱口令或未禁用明文协议，攻击者可通过暴力破解或预置凭据直接获得管理权限。

其攻击流程可分为：

1. 扫描目标网络识别管理服务（端口 22/23/80/443/161）；
2. 使用字典或暴力工具尝试登录，或利用已知管理账户登录；
3. 获得 shell 或 web 管理面板后修改配置或安装后门。



2.2 交换机面临的常见威胁分析

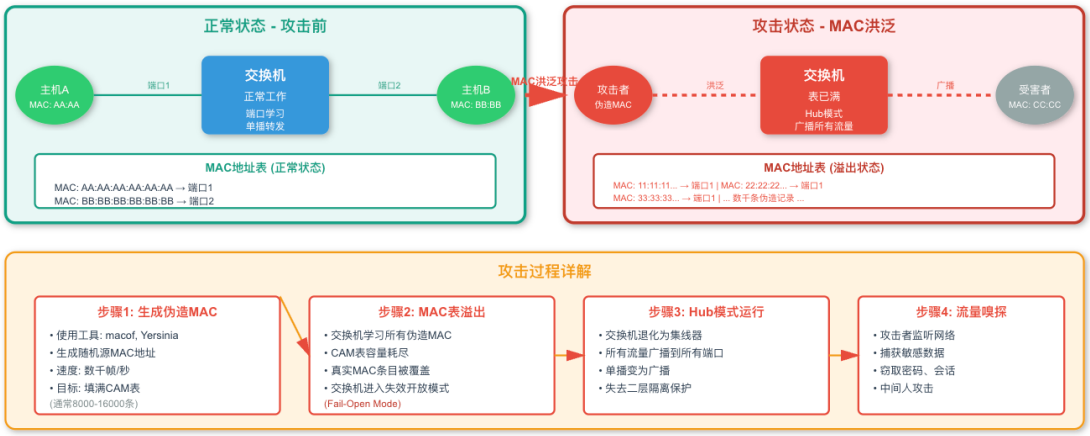
交换机在二层基于 MAC 学习转发帧，支持 VLAN 划分、生成树协议、端口安全、链路聚合等。安全模型应关注端口接入控制、VLAN 隔离、BPDU Guard、DHCP Snooping、动态 ARP 检测等措施。

2.2_1 MAC 地址表溢出攻击

交换机会维护有限大小的 CAM 表。攻击者发送大量源 MAC 地址帧，填满表项后交换机无法再正确学习真实 MAC，进入“退化模式”，攻击者便能嗅探跨端口流量。

其攻击流程可分为：

1. 攻击者通过受控主机快速发送大量带有随机源 MAC 的数据包；
2. 交换机 CAM 表被填满，从而无法查找目的 MAC；
3. 交换机选择广播/洪泛模式，流量暴露给攻击者所在端口。



2. 3 防火墙面临的常见威胁分析

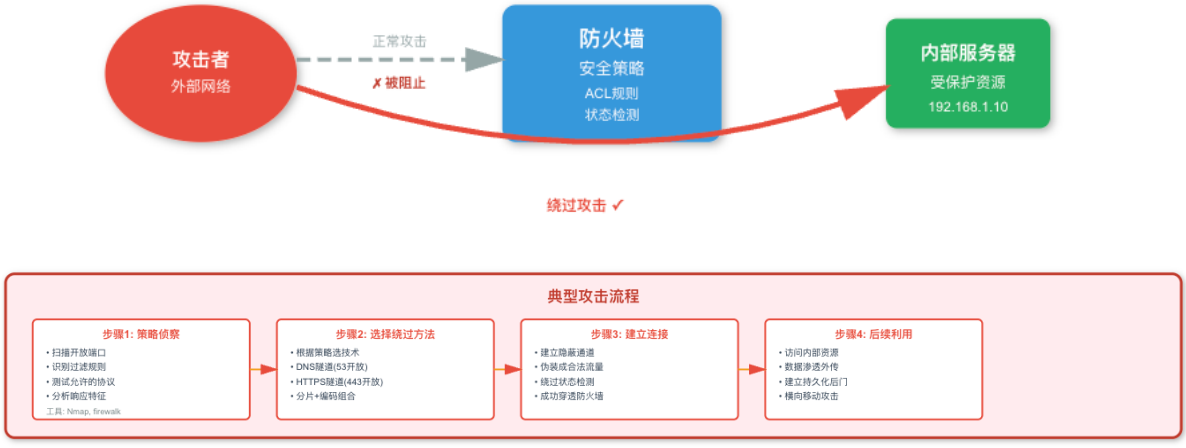
防火墙通过包过滤、状态检测、应用层网关和深度包检测实现访问控制。现代防火墙支持 NAT、IPS/IDS 集成、用户身份识别及 SSL 解密。

2. 3_1 策略绕过

攻击者利用未被防火墙规则覆盖或难以识别的通道（如 DNS、ICMP、HTTP 长连接、加密隧道）将恶意流量伪装成合法流量，从而绕过规则匹配。

其常见手段有：

1. DNS 隧道（将数据编码到 DNS 查询/响应中）；
2. ICMP 隧道（通过 ICMP payload 传输数据）；
3. HTTP 长轮询或 WebSocket 隧道化；
4. 封装在常见端口（如 443）上的自定义协议。



2. 4 无线 AC 面临的常见威胁分析

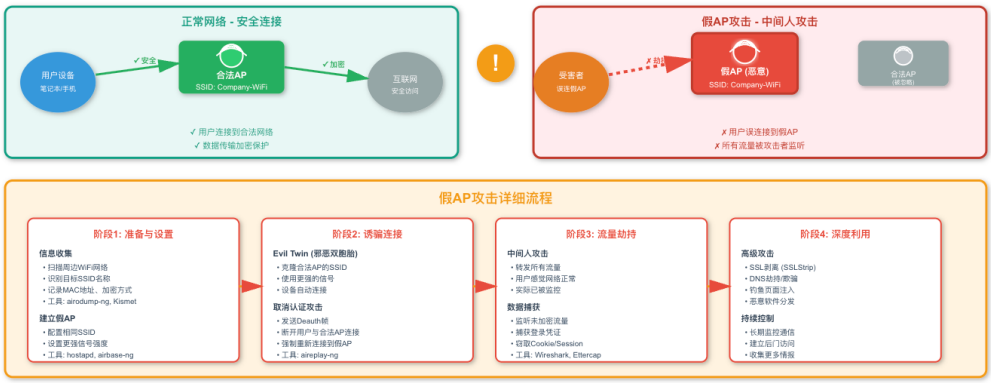
无线 AC 集中管理 AP，进行认证、射频优化、漫游管理与安全策略下发。安全模型包含：加密协议（WPA2/3）、RADIUS 认证、AP 固件管理、SSID/广播策略。

2. 4_1 假 AP 攻击

攻击者搭建伪造接入点，使用与合法网络相同或相似的 SSID，诱骗用户连接，从而进行流量嗅探、中间人攻击或凭据收集。

其攻击流程为：

1. 攻击者部署伪 AP，配置为强信号或采用更低延迟使客户端优先连接；
2. 通过 captive portal、SSL strip 或模拟登录页面窃取凭据，或直接进行流量转发捕获；
3. 若用户使用不安全协议或未验证证书，进一步窃取敏感数据。



2. 5 入侵防御(IPS)面临的常见威胁分析

IPS 实时拦截或阻断匹配已知攻击签名或异常行为的流量。IPS 可工作在检测（IDS）或阻断（IPS）模式，依赖签名库、协议解析、行为模型与机器学习特征。关键问题是签名更新频率、加密流量的可视性与误/漏报权衡。

2. 5_1 加密流量隐藏攻击

现代攻击大量隐藏在 TLS/HTTPS、DoH、QUIC 等加密协议中，传统基于明文特征匹配的 IPS 无法解析加密负载，从而产生“盲区”。

3. 网络攻防工具的分析

3. 1 Nmap 工具分析

3.1_1 Nmap 的用途

Nmap 的全称是 Network mapper，即“网络映射器”。它的核心功能是，发现网路上的设备，并且识别这些设备上运行的服务和操作系统。换句话说，它可以实现一下的功能：发现网络上有哪些主机是存活的；这些主机开放了哪一些端口；这一些端口上运行了哪些服务；目标主机使用了什么样的防火墙等问题。

3.1_2 Nmap 在各网络设备上的使用

路由器：Nmap 可快速发现路由器对外暴露的管理端口（22/23/80/443/161），结合 -sV 与 -O 得到服务版本与操作系统指纹；使用 NSE 脚本如 snmp-info、snmp-brute 枚举 SNMP 社区字符串并获取设备型号/序列号。通过这些信息可以判断厂商、固件版本及是否存在默认凭据暴露。注意高频探测和暴力枚举会触发告警并影响设备稳定性。

Nmap 在路由器中常用命令：

nmap -sV -p 22,23,80,443 〈router-ip〉

nmap -sU -p 161 --script=snmp-info 〈router-ip〉

nmap -sU -p 161 --script=snmp-brute 〈router-ip〉

nmap -O 〈router-ip〉

交换机：交换机通常把管理平面放在特定 VLAN 或端口，Nmap 可扫描管理端口并结合 TTL、服务 banner 与 --script http-enum、snmp-info 判断是否为管理界面；若发现在意外子网/端口上出现管理服务，说明存在非受控管理通道或 VLAN 漏洞。对交换机要重点关注 SNMP 只读/只写权限、管理界面是否在公网可达，扫描时避免同时扫描大量端口以免影响转发性能。

Nmap 在交换机中常用命令：

nmap -sV -p 80,443,22,161 〈switch-ip〉

nmap --script=snmp-info 〈switch-ip〉

nmap --script=http-enum 〈switch-ip〉

防火墙：防火墙对探测流量的处理方式能反映其策略和状态。用 SYN（-sS）、ACK（-sA）、FIN（-sF）等不同扫描类型可观察哪些包被丢弃、哪些被重置或转发，从而推断出入站/出站规则、状态检测能力与隐蔽策略。该方法适合评估规则覆盖，

但在生产环境可能触发防护或日志风暴，务必按低频率与分批次执行并取得授权。

Nmap 在防火墙中常用命令：

nmap -sS <firewall-ip>

nmap -sA <firewall-ip>

nmap -sF <firewall-ip>

nmap -f <firewall-ip>

无线 AC：无线 AC 的管理通常运行在 HTTP/HTTPS、SSH 或专有端口上，Nmap 可发现这些管理端口并识别版本与证书信息；结合无线嗅探可以关联 BSSID 与 AC 管理 IP，判断是否存在未注册或远程可管理的 AP。注意无线场景下要结合物理/射频视角来判断管理接口是否被滥用或中间人劫持。

Nmap 在无线 AC 中常用命令：

nmap -sV -p 80,443,22 <ac-ip>

nmap --script ssl-cert <ac-ip>

nmap -sU --top-ports 20 <ac-ip>

IPS：对 IPS 的评估通常通过发送多种探测来观察是否被拦截或生成告警；Nmap 的多样扫描和 NSE 脚本可模拟常见探测样式，结合监控端/日志可以判断 IPS 的签名覆盖、抗扫描能力及对流量畸形的容忍度。进行此类测试时必须在受控环境或获得许可，否则会造成误阻断或合规问题。

Nmap 在 IPS 中常用命令：

nmap -sS <ips-ip>

nmap -sA <ips-ip>

nmap -f <ips-ip>

nmap --scan-delay 200ms <ips-ip>

3.1_3 Nmap 的优缺点

- 优点：灵活多样的扫描方式、强大的脚本引擎、广泛的协议支持、快速识别网络资产与拓扑。

- 缺点：高频扫描易触发 IPS/防火墙、对加固设备或混淆协议识别受限；扫描本身不等于漏洞验证。

3.2 Nessus 工具分析

3.2_1 Nessus 的用途

Nessus 是一款功能强大、全面的漏洞扫描器。如果说 Nmap 是告诉我们“门在哪里、门后面可能是什么”，那么 Nessus 就是走过去，尝试拧动门把手、检查门锁的型号、甚至发现锁匠忘记上锁的后门，然后给你一份详细的报告，告诉你“哪扇门没关、哪把锁是坏的、哪个窗户可以被撬开，以及这些问题的严重程度”。

换言之，Nessus 是一款主动型的安全评估工具，它通过模拟攻击者的技术，系统地发现和评估网络设备、服务器、应用程序中已知的安全漏洞、错误配置、合规性偏差等问题。

3.2_2 Nmap 在各网络设备上的使用

路由器：Nessus 可对路由器进行全面的漏洞扫描，包括管理接口（SSH/Telnet/HTTP/HTTPS）的弱口令检测、固件版本漏洞识别、SNMP 社区字符串暴露检查等。其插件库可自动识别厂商型号，并匹配对应的 CVE 漏洞，帮助评估路由器控制平面存在的安全风险。

交换机：在交换机上，Nessus 能扫描管理平面暴露情况，如 HTTP/HTTPS 控制台、SNMP 读写权限是否过大，并检查常见的交换机固件漏洞。插件还可以识别是否存在未授权访问、默认凭据、配置文件泄露等问题，从而定位潜在的管理 VLAN 或管理口暴露风险。

防火墙：Nessus 可针对防火墙固件与特性模块执行漏洞扫描，例如策略管理界面漏洞、弱口令、远程代码执行漏洞等。通过与防火墙交互的扫描过程，还能判断是否存在不安全的管理端口暴露，并识别防火墙是否存在错误配置导致的过宽放行。相比 Nmap，Nessus 更突出漏洞与配置层面的分析能力。

无线 AC：Nessus 可扫描无线 AC 的 Web 管理接口、SSH/HTTPS 服务、CAPWAP 管理管道安全性，并识别 AC 固件中的历史漏洞。借助其插件库，可检测常见厂商

的默认配置、弱口令风险、未打补丁的管理模块漏洞，辅助评估无线网络控制面安全。

IPS：由于 IPS 通常会主动拦截攻击流量，Nessus 扫描可用于评估 IPS 对特定探测行为的响应，例如是否会对探测流量做预警、是否阻断漏洞利用测试。Nessus 也能识别 IPS 管理接口与固件漏洞，但更重要的是通过被动观察判断 IPS 的检测粒度和策略配置是否存在缺陷。

3.2_3 Nessus 的优缺点

- 优点：全面的漏洞库、易于上手的报告功能、支持合规审计模板（PCI、CIS）
- 缺点：无法对所有设备做深度利用验证；对专有硬件或者闭源固件的漏洞识别有限

3.3 Metasploit 工具分析

3.3_1 Metasploit 的用途

Metasploit 是一个开源的、功能完善的渗透测试框架。它不仅仅用于发现问题和评估风险，更用于实际利用漏洞、验证其影响、并最终实现渗透目标。

3.3_2 Metasploitt 在各网络设备上的使用

路由器：Metasploit 可用于验证路由器的真实可被利用漏洞，包括默认账号利用、固件已知 RCE 漏洞、配置泄露漏洞等模块。框架内含大量针对 Cisco、Huawei、MikroTik 等路由器的 exploit，可用于模拟攻击者行为验证漏洞是否可被成功利用。此外，Metasploit 的 auxiliary 模块可用于 SNMP 枚举、配置备份抓取与路由协议弱点测试。

交换机：对交换机而言，Metasploit 主要发挥漏洞验证与管理面安全测试的作用。可利用模块尝试默认凭证登录、SNMP 读写权限滥用以及一些厂商固件的历史漏洞验证。其辅助模块可执行 MAC 地址表枚举、VLAN 配置探测等操作，用来判断交换机是否存在配置面暴露问题或可被利用的管理接口，帮助验证前期扫描结果的实际可利用性。

防火墙：Metasploit 在防火墙测试中主要用于验证管理界面漏洞，例如 Web 管理页面的命令注入、认证绕过、文件读取漏洞等。部分防火墙存在公开 exploit，可在 Metasploit 中直接利用。通过辅助模块，研究者还可对防火墙策略进行探测，如探测 NAT/ACL 是否允许某些探测流量穿透，以验证策略配置是否存在缺陷。

无线 AC：Metasploit 可用于扫描和利用无线 AC 的 Web 后台漏洞、API 接口认证绕过或固件级 RCE 漏洞。部分 AC 管理平台存在默认账户、弱加密、上传漏洞等，Metasploit 中的相关 exploit 可用来验证这些风险。其辅助模块还可进行无线设备识别、后台接口探测，从而帮助研究者评估无线控制器的管理面是否暴露或可被远程利用。

IPS：Metasploit 对 IPS 的测试重点不在于绕过检测，而在于验证其管理平台是否存在漏洞。例如 Web 管理平台的命令注入、权限提升、登录绕过等均可能在 Metasploit 的模块库中找到。此外，通过使用不同类型的扫描或 exploit 流量，可观察 IPS 是否能够正确识别、阻断攻击行为，以此间接测试其规则库有效性、检测策略与误报/漏报情况。

3.3_3 Metasploit 的优缺点

- 优点：可真实验证漏洞利用链、评估漏洞可利用性与影响范围；插件丰富，适合模拟真实攻击
- 缺点：使用风险大、法律风险高、需要专业技能进行安全清理与恢复。

4. 网络攻防工具的对比与总结

攻防工具类别	Namp	Nessus	Metasploit
工具定位	信息收集，端口扫描	综合漏洞扫描器	漏洞利用与验证框架
核心能力	端口/服务识别，OS 指纹，NSE 基础漏洞检测	CVE 匹配，固件漏洞扫描，配置基线检测	利用已知漏洞，权限提升，攻击模拟
对路由器的作用	管理口，SNMP，版本识别	固件漏洞，弱口令扫描	利用默认账号或 RCE 模块测试漏

			洞
对交换机的作用	管理口，SNMP，VLAN 暴露检测	配置错误，固件漏洞检测	验证弱口令或特定历史漏洞利用
对防火墙的作用	策略探测，端口过滤判断	VPN/管理面漏洞检测	利用防火墙 web/RCE 漏洞验证可利用性
对无线 AC 的作用	管理口与 web 服务	Web 与固件漏洞扫描	后台认证绕过，固件漏洞利用

Nmap、Nessus 与 Metasploit 是网络攻防中使用最广泛的三类工具，它们分别覆盖信息收集、漏洞扫描与漏洞利用三个不同层面的能力，因此在网络设备安全评估中形成互补关系。

首先，从功能定位来看，Nmap 主要用于端口扫描、服务识别与基础安全探测，属于信息收集层级工具。它通过多种扫描技术（SYN Scan、ACK 扫描、FIN 扫描等）评估设备暴露面，并能通过 NSE 脚本实现基础漏洞检测。相比之下，Nessus 属于全面漏洞扫描器，能够结合 CVE 数据库对路由器、交换机、防火墙、无线 AC、IPS 与网闸进行深度检测，包括弱口令、固件漏洞、Web 后台漏洞、协议配置缺陷等。Nessus 的强项在于覆盖度高、报告结构完善，但不具备真正的漏洞利用能力。而 Metasploit 则定位于漏洞验证与利用框架，通过 exploit、payload 和 auxiliary 模块来模拟真实攻击者行为，对 Nessus/Nmap 发现的弱点进行可利用性验证，从而评估风险的真实严重性。

其次，从对网络设备的适配性来看，Nmap 对所有设备的管理面识别能力最强，可作为第一阶段侦察工具使用；Nessus 则对有固件漏洞历史的设备（如路由器、防火墙、无线 AC）检测效果最显著；Metasploit 更适合于存在明确 exploit 的设备版本，如部分厂商的路由器、防火墙或无线控制器。对于 IPS 和网闸，Nmap 和 Metasploit 的作用相对受限，而 Nessus 仍能通过管理面扫描与固件检测发挥作用。

再从攻击面深度来看，Nmap 能发现暴露端口与潜在配置风险，Nessus 能识别漏洞本身，而 Metasploit 能验证漏洞是否能够被真正利用，因此三者形成由浅到深的完整链条：暴露面 —— 漏洞 —— 可利用性。

综合来看，Nmap 更偏向快速发现问题，Nessus 偏向系统化检测风险，而 Metasploit 偏向深度验证威胁。在网络设备的安全评估中，三者常常结合使用：Nmap 负责发现攻击入口，Nessus 负责识别并量化风险，Metasploit 负责验证风险的真实可利用性，从而形成完整的评估闭环。